ローカルエージェント認証：技術スパイク結果

判定: ローカルのOAuth→MCP接続は成立。実ASと準拠端末の成立は未確認。 独立repo、非機密のwhoamiだけ。2026-10-05 / Bun 1.3.11 / 公式MCP SDK 1.32.1。 実AS/管理ポリシーの設定変更・deployは行っていない。

確認済み（合成issuer、loopbackのみ）

- 公式SDKクライアントで401→PRM→AS metadata→code/S256→Bearer→tool呼出しが成功。 事前登録client IDを使い、DCR・client secretは不要。JSON Streamable HTTP、revision 2025-11-25。

- 別署名/iss/aud/client、期限切・exp欠落・scope欠落/部分一致、ID token、未対応subjectを拒否。 不正Origin/Hostとローカル迂回routeを拒否。identity headerで認可を上書きできない。

- strict ASはPKCE省略を拒否。optional ASは省略したcode交換も成功し、差を再現。verifier省略/不一致、code再利用、callback state不一致/欠落/期限切/再利用を拒否。

- group剥奪後は同じBearerを403、合成照会障害は503。refresh admissionと毎回認可を分離。 合成rotation後の旧refreshは拒否。groupを見ない直接refreshは成功してもMCPで拒否。

- 有効Bearerの再使用は成功する。PKCEやCAによる端末bindingの証拠にはならない。OIDC nonce不一致の局所試験は拒否。通常SDKフローはID token/nonceを要求しない。型検査・24テスト成功。証拠: artifacts/test-summary.json、artifacts/smoke.json。秘密値は記録しない。

実環境で未確認

実Cognito→Broker Entra→home Entra B2B、Intune準拠/CA・claim trust、実public client/callback、 JWT issuerとauthorize domainのdiscovery、custom scope/resource/aud、主体mapping、Graph live照会、 refresh後のdevice/group失効時間、JWKS更新、HTTPS/直接originのIAM拒否、実desktop MCP client。 ブラウザ操作は合成で、企業OS/browserによるdevice claim伝達も未試験。外部LLMは使用していない。

設計への修正・比較

Cognito→Broker→home / 既存連合の再利用候補。AWS資料ではPKCE省略が任意なので、AS強制を前提にしない。仲介を採るなら直接発行の迂回を閉じる別設計が必要。

Entra直接＋本人の委任scope / 認証用途なら比較対象。resourceの登録URI、API app IDのaud、tid/oid/azp/scpを別profileで検証する。client/APIの再利用可否とCAを先に読む。

clientのPKCE送信とASの省略拒否を分ける。callback所有者がstateを検証する。OAuthとOIDCを混同せず、nonceはOIDC採用時のみ検証する。Bearer replay/端末bindingは未解決。 毎回認可をrefreshだけへ置換しない。MCP revisionを実client対応に合わせ、2026版互換を宣言しない。 SDK OAuth失敗後の再接続にはtransportを再生成する。実AS・準拠端末の実証には承認済み実機試験が要る。

根拠: AWS authorize / AWS token / MS MCP / MS claim validation / 公式SDK。 次: 既存設定を正規に読むための非秘密IDと読取経路を確認し、不足設定の最小変更案を承認後に試す。